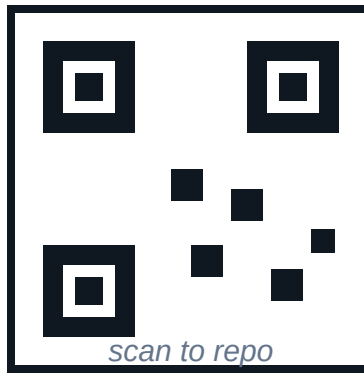


Non-Executing Security Analysis of AI Model Supply-Chain Artifacts



Provenance, Serialization, Impersonation, and Repository Risk Inspection

Pooja Kiran

Security Engineering • AI / Agent Security • Cloud Security

Apache-2.0 • Python 3.12 • HEAD 7b2cd5f • verified 2026-09-26

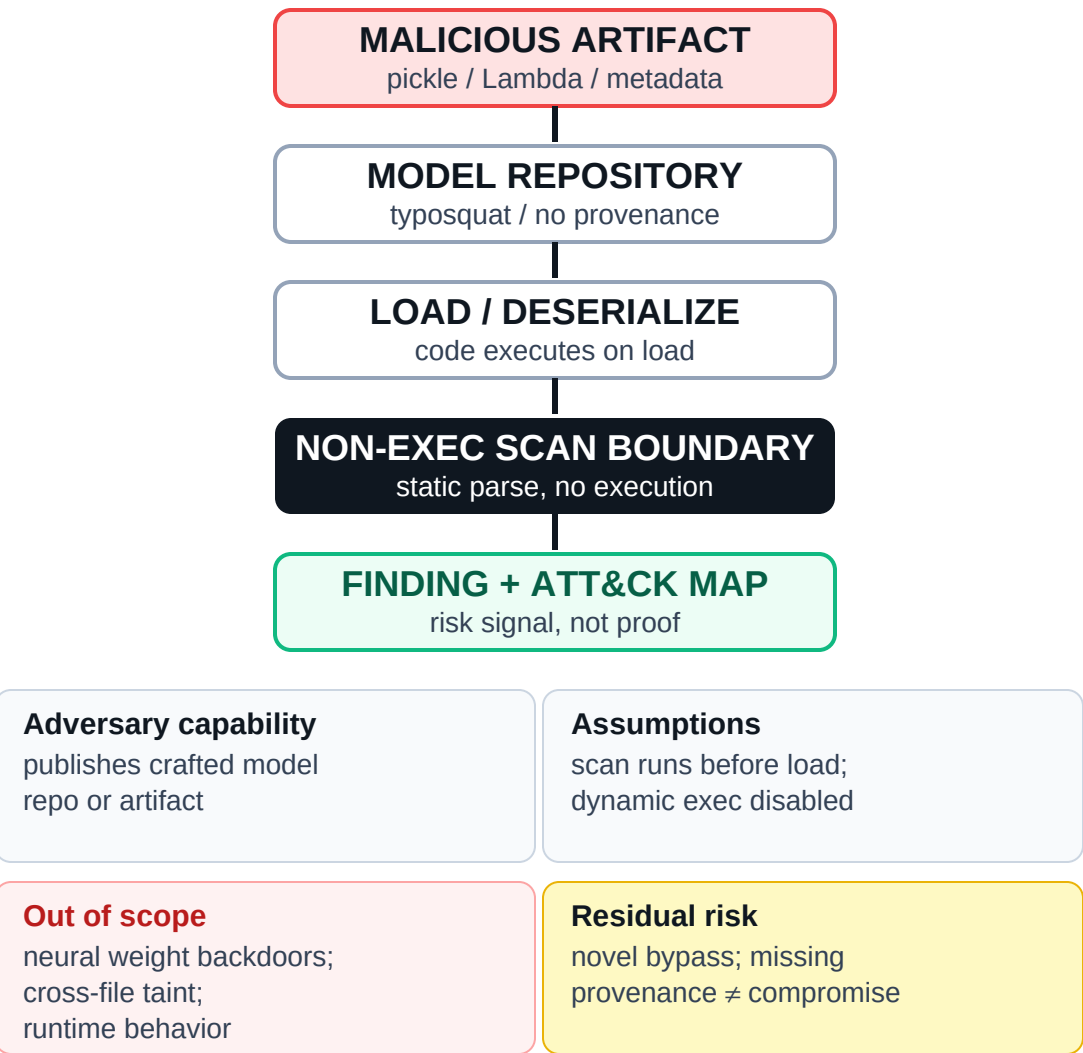
RESEARCH QUESTION

Can important model supply-chain risk signals be identified without loading or executing untrusted model artifacts?

01 · THE FAILURE MODE

Loading a model can execute code. Pickle-based checkpoints run arbitrary opcodes on deserialize; Keras Lambda layers and ONNX custom ops load native code; typosquatted repos impersonate trusted ones. The danger is realized the moment an artifact is loaded — so inspection must happen before that.

02 · THREAT MODEL



03 · OBJECTIVE

Determine whether static parsers + pattern/taint/symbolic analysis can surface supply-chain risk signals across model formats without execution.

- 01 – Pickle opcode + 5 binary formats
- 02 – AST / taint / symbolic string engines
- 03 – Provenance & impersonation checks
- 04 – ATT&CK v19 mapping on findings

HERO · NON-EXECUTING SCAN ENGINES

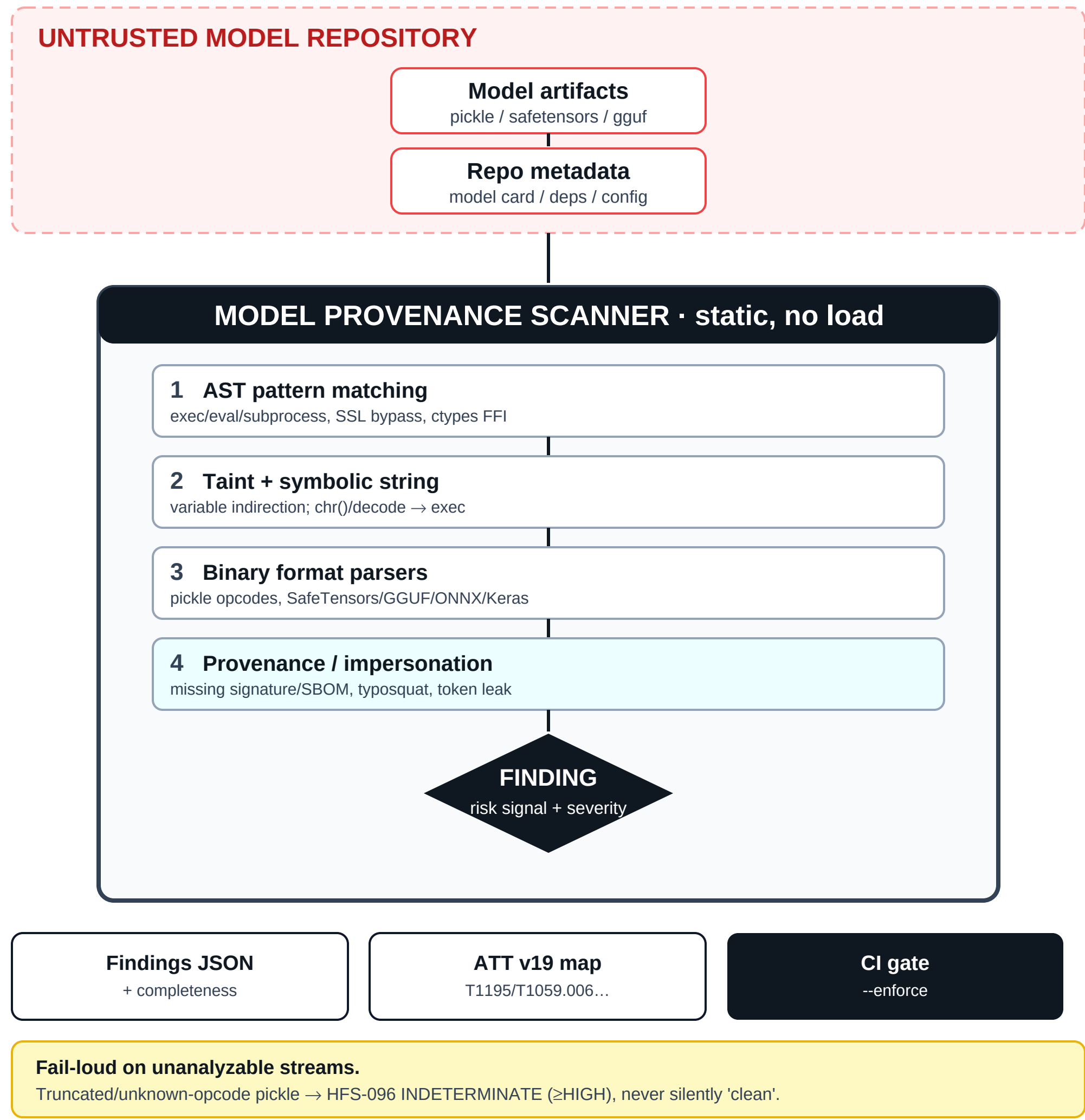
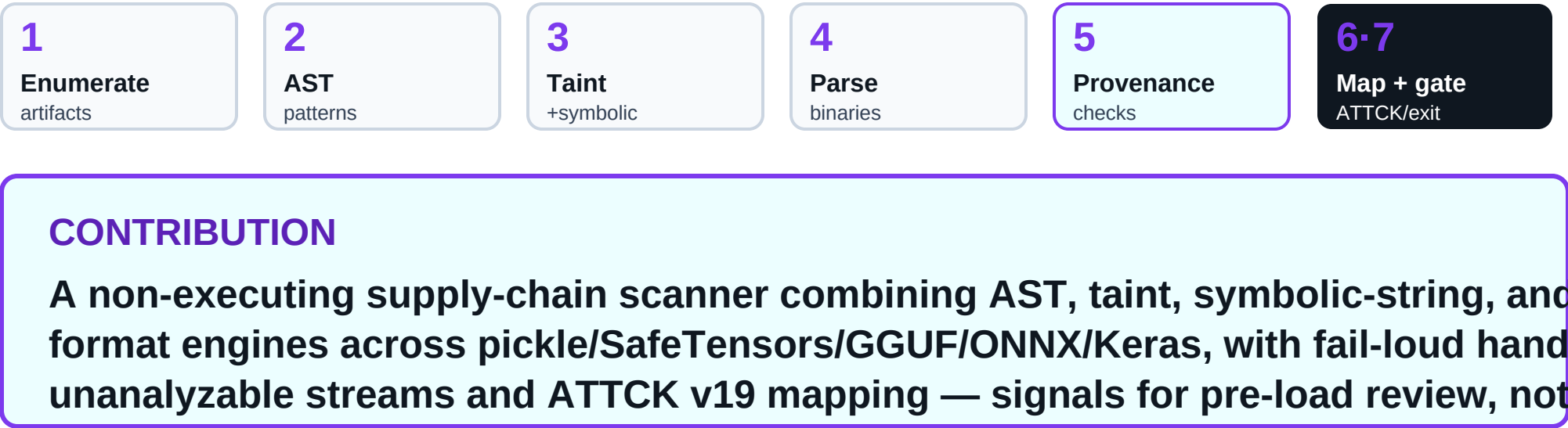


Figure 1. Five static engines inspect artifacts without loading them; findings map to ATTCK v19. Dynamic execution is not modeled.

METHOD · SCAN LIFECYCLE



RESULTS · COMMITTED FIXTURE SUITE

33/33
FIXTURES DETECTED

0
BENIGN FP (of 4)

12 core + 18 extended + 3 large-scale fixtures.
Fixture-suite result — NOT a general detection rate.

Verified surface	
Binary format parsers	5
PickleScan bypasses caught	7
Analysis engines	5

FIXTURE DETECTION BY SUITE

Core incidents	100%
Extended variants	100%
Large-scale	100%

Committed fixtures only (redteam_report.json). Do not generalize to arbitrary HF repos.

HISTORICAL CI SNAPSHOT

Main CI 36043740861 (751a62a, 2026-09-24):
211 passed + 6 subtests; 66.9% coverage
(Py 3.11/3.12), gate 55%. Not re-run at current HEAD.

NOT ESTABLISHED BY THIS REPO

General detection/false-positive rate on arbitrary models. Neural backdoors. That an artifact is benign.

SECURITY BOUNDARY

PROTECTS / DETECTS

- pickle opcode risk
- 5 binary formats
- typosquat / provenance
- token exposure
- unanalyzable = HIGH

DOES NOT ESTABLISH

- neural weight backdoors
- cross-file taint
- runtime behavior
- GPU-gated payloads

INSPECT BEFORE EXECUTION

LIMITATIONS

- 1. Fixture results ≠ real-world detection rate.
- 2. No broad benign false-positive benchmark.
- 3. Cannot detect weight-space neural backdoors.
- 4. Cross-file / whole-program taint not modeled.
- 5. Missing provenance is a signal, not proof.

FUTURE WORK

- Broad benign-model FP benchmark.
- Whole-repo cross-file taint analysis.
- Larger real-model corpus.
- Published latency benchmark artifact.
- Signature/SBOM verification depth.

CONCLUSION

Five static engines surface supply-chain risk signals across model formats without loading them, failing loud on unanalyzable inputs. Evidence is a committed 33-fixture suite — strong on those fixtures, not a measured rate on arbitrary repositories.

REPRODUCE

```
pytest tests/
python tests/redteam/simulate_attacks.py
```